WebTerm/3270 Security Tools

Prepared by Britley Hoff | October 15, 2026

Every tool below lives in one open source bridge and browser client, no desktop emulator, no separate scanner install. Connect to any TN3270(E) or TN5250 host (z/OS, z/VM, IBM i, z/TPF) through the bridge, unlock the Security panel, and run the tool against the live session. All of it is built FOR AUTHORIZED USE ONLY, on an engagement where you already have permission to test the target.

This sheet is a quick reference for explaining a tool on the spot: what it does, how you actually run it, and the one sentence that answers "so what." Full walkthroughs, screenshots, and tutorial write-ups live in the project's own DOCUMENTATION/webterm-security-tools-tutorial.md.

Platform key: z/OS (TSO/RACF/SDSF/DB2/CICS) · IBM i (AS/400) · z/VM · z/TPF · Cross (any protocol/session)

Cross-Protocol & Session-Level

Tool	What It Does	Direct Use	Benefit
Field Map Overlay	Highlights every field's boundaries and attributes on the live screen.	Toggle it on any connected session.	Shows at a glance which fields are protected, hidden, numeric, or MDT.
Attribute Byte Inspector	Decodes the raw FA byte for any field you click.	Click a field after connecting.	Confirms exactly what a field is doing.
Color Reveal	Reveals color, MDT and intensity info.	Watch a password or other hidden field.	Defeats color-on-color and non-display tricks.
Field Length Disclosure	Reveals the full length of hidden fields.	Read the field's length.	Helps size a wordlist or payload.
Traffic Recorder / Replay	Records every keystroke and screen update.	Open it after a session.	Gives you a timestamped log for evidence.
Session Viewer	Plays a recording back with pause, step, and speed control.	Load a saved recording.	Lets you review a session without touching the host.
Wire Inspector + Protocol Decoder	Shows the raw bytes and decodes TN3270/TN5250 commands.	Open it alongside any session.	Helps you understand what is actually on the wire.
Proxy Viewer	Shows the bridge's own activity log.	Open it during a session.	Confirms what the bridge is doing.
Brute-Force Operator Screen	Tries a wordlist against a logon screen, with delay, jitter, and lockout detection.	Point it at a logon screen and load a wordlist.	Finds weak passwords while avoiding account lockouts.
MITM Intercept	Captures credentials typed by a user who connects through the bridge.	Arm it, then interact with the session normally.	Demonstrates how a rogue bridge would harvest passwords.
Credential Harvest Log	Stores every captured username and password.	Review it after the MITM test.	Gives you a ready-made finding for the report.
Screen Watch	Alerts you when specific text appears on the screen.	Enter the text to watch for.	Lets you wait for a prompt without staring at the screen.
Session Broadcast	Mirrors one session to many viewers in real time.	Open multiple tabs, type a share code.	Lets a team watch a test together.
Protocol Fuzzer	Sends malformed 3270 data streams to the host.	Pick a mode, pick a target, and run.	Tests how robust the host's 3270 parser is.
TN3270E Negotiation Probe	Tests which TN3270E features the host supports.	Point it at any session.	Documents the host's protocol capabilities.
XTALK Operator Probe	Checks whether the host accepts XTALK commands.	Connect, then run the probe.	Flags a rarely-tested command channel.
Host Session Monitor Dashboard	Shows all active sessions and their status.	Open it during a test.	Gives you a single view of everything in progress.
Passive ESM Fingerprint	Identifies the host's security software from its responses.	Connect and sign on.	Tells you what you are up against before you start.
SSH No-Credential Access Checker	Tests whether an SSH host accepts a blank password.	Enter a host, port, and username, run the check.	Catches misconfigured accounts before anyone else does.

z/OS (TSO · RACF · SDSF · DB2 · CICS)

Tool	What It Does	Direct Use	Benefit
RACF Probe	Sweeps a credential wordlist against a logon screen (TSO, z/VM, CICS, one attempt at an empty password, only if the target actually offers it.		

z/TPF, or IBM i), with an optional "keep going" enumeration mode.

Navigate to a logon screen, load or type a wordlist, run.	The classic default-credential check, automated and classified

	(success / failure / lockout / enumerated) instead of typed by hand one at a time.
RACF Settings Analyzer	Reads global RACF options straight from TSO

READY.

Run from READY. Flags weak system-wide policy (password rules,

SETROPTS options) without needing special access.

RACF User/Group Enumerator	Enumerates users and groups	Run from READY.	Builds the target list for the RACF checks.
Dataset Recon Scanner	Discovers dataset names and	Run from READY.	Surfaces privilege escalation and
Encryption Audit Scanner	Checks specific datasets	Feed it names from the	Confirms whether sensitive
VTAM Applid Enumerator	Sweeps DISPLAY NET,ID=applid,	Run from READY.	Maps all VTAM APPLIDs actually
APF Library Scanner	Enumerates APF-authorized	Run from READY.	Identifies APF libraries that
APF Writability Checker	Attempts to add a dataset	Run from READY, right	Confirms whether the APF
PARMLIB Access Check	Checks read/write access to	Run from READY, right	Determines whether PARMLIB
SDSF Job Parser	Parses saved SDSF job	Navigate to SDSF, run	Extracts structured data from
SDSF Job Output Retriever	Pulls the spool content of	Run from an SDSF job list.	Captures job output for offline
RACF Profile Scanner	Dumps selected RACF profiles	Run from TSO READY.	Produces a profile inventory for
DB2 Subsystem Scanner	Identifies DB2 subsystems	Run from TSO READY.	Maps DB2 attack surface before
RACF-DB2 Authority Scan	Audits RACF authority	Run from TSO READY.	Finds DB2 resources that
DB2 Connection Analyzer	Analyzes DB2 connection-level	Run from TSO READY.	Identifies misconfigured or
CICS Transaction Scanner	Probes CICS transaction IDs	Run from TSO READY.	Maps the CICS application
Cross-Session Buffer Bleed	Detects residual CICS screen	Clear the CICS screen, sign on as one user, disconnect, reconnect with the same LU name within ~90 seconds.	Confirms whether CICS clears terminal buffers between sessions, preventing data from one user's session appearing in another's.

IBM i (AS/400)

Tool	What it Does	Direct Use	Benefit
Default Credential Audit	Tries the standard IBM-supplied default passwords (QSECOFR, QPGMR, QUSER, QSYSOPR, QSRV, QSRVBAS, QTCP, QTMPLPD, QTMHHTP1, QTMHHTP2, QTFTP, QNETSPLF, QDBSHR, QDFTOWN, QAUTPROF) to see which profiles still have factory passwords in place.	Before signing on, paste or type one, stop at a menu,	Turns an engagement's "default credentials" finding from a hypothesis into a confirmed, reproducible result.
System Value Security Analyzer	Reads the system values that govern password rules (QPWDMINLEN, QPWDRQDDIF, QPWDEXPITV, QPWDLVL, QPWDRQDDGT, QPWDRQDUPR, QPWDMAXLEN, QPWDHISTLEN, QPWDLMTAJC, QPWDLMTCHR, QPWDLMTREP, QPWDPOSDIF, QPWDVLDPGM, QMAXSIGN, QMAXSGNACN, QINACTITV, QINACTMSGQ, QDSPSGNINF, QLMTDEVSSN, QLMTSECOFR, QRETSVRSEC, QRMTSIGN, QSECURITY, QSHRMEMCTL, QALWOBJRST, QALWUSRDMN, QAUDCTL, QAUDENDACN, QAUDFRCLVL, QAUDLVL, QAUDLVL2, QCRTAUT, QCRTOBJAUD, QDSCJOBITV, QDEVRCYACN, QFRCCVNRST, QINACTJOB, QLMTSECOFR, QMODEL, QPWDEXPWRN, QPWDLVL, QPWDMAXLEN, QPWDMINLEN, QPWDRQDDGT, QPWDRQDDIF, QPWDRQDUPR, QPWDVLDPGM, QRETSVRSEC, QRMTSIGN, QSECURITY, QSHRMEMCTL, QSYSLIBL, QUSEADPAUT, QVFYOBJRST) and flags weak or dangerous settings.	Run from a menu.	Gives the IBM i equivalent of a CIS Benchmark assessment in one pass.
Special Authority Audit	Lists every user profile that holds powerful special authorities (*ALLOBJ, *SECADM, *JOBCTL, *SPLCTL, *SAVSYS, *SERVICE, *AUDIT, *IOSYSCFG) and ranks them by risk.	Run from a menu.	Shows exactly who can do what, so you can challenge each grant and remove the ones that aren't needed.
Object-Level PUBLIC Authority Scanner	Finds objects whose PUBLIC authority is more permissive than the default, including world-writable IFS objects.	Run from a menu.	Catches the misconfigurations that let any user read, change, or delete data they shouldn't touch.
Network Attributes Analyzer	Reads the system network attributes (DDMACC, PCSACC, JOBACN, ALWADDCLU, NETSERVER, DFTNETMODE) and flags insecure settings.	Run from a menu.	Identifies how the system will behave when other machines try to connect to it.
Job Description PrivEsc Scanner	Checks job descriptions for dangerous settings, such as a USER profile that points to a powerful user profile.	Run from a menu.	Finds hidden paths to elevated privileges that don't show up in a simple user-profile review.
Authorization List Scanner	Enumerates authorization lists and their entries to show who can access the objects secured by each list.	Run from a menu.	Makes it easy to find and clean up over-broad access granted through shared lists.
Active Job Scanner	Lists active jobs and their attributes, including the user profile they run under and the subsystem they're in.	Run from a menu.	Helps you spot jobs running with more authority than they need.
Exit Point & Service Registration Audit	Reviews registered exit programs and network server configurations (e.g., FTP, ODBC, REXEC) for weak or unexpected entries.	Run from a menu.	Finds backdoors and misconfigured services that bypass normal sign-on controls.
SMB Share & Session Enumerator	Lists the file shares exposed by the IBM i SMB server (IBM i Access for Windows) and the sessions currently connected to them.	Run from a menu.	Shows what data is reachable over SMB and who is using it right now.
CFGPRF Permission Sweep	Checks the permissions on configuration files (CFGPRF) and flags ones that are too open.	Run from a menu.	Protects connection profiles that may store credentials or sensitive settings.
Adopted-Authority Runtime Scanner	Detects programs that are currently running with adopted authority, including those owned by powerful profiles.	Run from a menu.	Reveals privilege escalation in progress, not just potential.
Stream/Command-Line Bypass Probe	Tests whether the command-line and stream-file interfaces can be used to run commands that menu restrictions would normally block.	Run from a menu.	Verifies that "locked down" menus actually lock down.
TLS Currency Probe	Connects to each TLS-capable service and records the protocol version and cipher it negotiates, flagging anything below TLS 1.2.	Run from a menu.	Shows which services will break when clients stop accepting old TLS, with time to fix them first.
Listening Services Inventory	Lists every TCP service the host is listening on, with its port, bind address, and whether it is encrypted. Plaintext services are flagged.	Run from a menu.	Gives a complete picture of the network attack surface, including services nobody remembers enabling.
Certificate Inventory	Enumerates the certificates in the system and application certificate stores, with their expiry dates and issuers.	Run from a menu.	Prevents outages from expired certificates and surfaces self-signed or weak ones.
Hardcoded Credential Finder	Searches source files for embedded passwords, API keys, and connection strings that should not be in code.	Run from a menu.	Finds secrets that would otherwise sit in plain text in repositories and backups.
Dependency Vulnerability Scanner	Checks the project's dependency manifest against a vulnerability database and reports known-vulnerable packages.	Run from a menu.	Catches vulnerable third-party code before it ships, with a clear fix for each finding.
Insecure Configuration Detector	Flags risky configuration patterns, such as debug mode enabled, permissive CORS, or missing security headers.	Run from a menu.	Turns a checklist of "things that should be off" into an automated, repeatable check.
Secrets Rotation Tracker	Records when each credential was last changed and reports those that are overdue for rotation.	Run from a menu.	Keeps long-lived secrets from quietly becoming permanent liabilities.

	judgment, confirm columns and UDP rows on your release.
Default Password Report	Runs ANZDFTPWD ACTION(NONE) and rates every profile whose password equals its name: CRITICAL if it holds ALLOBJ or SECADM, else HIGH. Report only, nothing guessed, no lockout risk. For a client-assisted audit, the Default Credential

	Audit is the pentest version.
Group Profile Review	Reads QSYS2.GROUP_PROFILE_ENTRIES and QSYS2.USER_INFO via STRSQL (all pages) and flags group profiles holding ALLOBJ or SECADM, and users who reach one only through a supplemental

	group, which the primary group field never shows. Stale empty groups are not found.
QSECOFR-Owned Objects	Reads QSYS2.OBJECT_OWNERSHIP via STRSQL for objects QSECOFR owns outside Q libraries and rates each library: HIGH when programs are among them (one that adopts its

	owner runs as QSECOFR), MEDIUM for data only. Fix is CHGOBJOWN to a dedicated owner profile, test first.
Library CRTAUT Review	Reads QCRTAUT (DSPSYSVAL) then DSPLIBD per application library and rates the authority new objects actually get: the library's own CRTAUT wins unless

		it says SYSVAL. ALL critical, CHANGE high, USE/EXCLUDE fine. Fix is CHGLIB ... CRTAUT(EXCLUDE), existing objects are not changed.
Static Scan	Adopted-Authority	Reads whole libraries via STRSQL (PROGRAM_INFO, OBJECT_PRIVILEGES, USER_INFO) for every program with

	USRPRF(OWNER), its owner, and PUBLIC's authority. Powerful owner (ALLOBJ/SECADM) plus PUBLIC above USE is CRITICAL, plus PUBLIC able to run it is HIGH. Name the libraries, blank reads every non-Q library and can be slow.
Output Queue and Spool Audit	Reads OUTPUT_QUEUE_INFO and OBJECT_PRIVILEGES via STRSQL for who can read

	spooled output: DSPDTA, OPRCTL, AUTCHK, PUBLIC per queue, remote queues, QPJOBLOG/QPRINT, SPLCTL and JOBCTL holders, and whether QAUDLVL has SPLFDTA and PRTDTA. DSPDTA open plus PUBLIC readable is CRITICAL. Name the libraries, blank reads every non-Q library. Get the client's signed list of sensitive queues.
Audit Journal Review	Reads QSYS/QAUDJRN through QSYS2.DISPLAY_JOURNAL for restores (OR RA RO

	RP), creates (CO), changes (ZC), spool (SF) and print (PO) grouped by user, after checking auditing is on (QAUDCTL) and each type's level is set. Auditing off is HIGH, a restore of an adopting program is HIGH, zero entries only counts when the level is set, QSECOFR rates a step higher. Days-back box, up to 365.
Exit Program Integrity and Authority	Lists registered exit programs outside Q libraries

	(EXIT_PROGRAM_INFO), reads PUBLIC on each program and its library, the owner, and the audit journal for the program being created, changed or restored in 90 days. PUBLIC ALL on a program is CRITICAL, CHANGE or a writable library HIGH. Owner shown, not rated. CHKOBJITG is not run, it needs a scope you choose on the box.
FTP Service Audit	Network check of the IBM i FTP server (21 and 990,

mock 2121 and 2990). Banner and pre-login SYST leaks, whether clear text sign-on is accepted (USER only, never PASS), TLS version and certificate, anonymous sign-on. Optional: default profiles (needs RoE activity ftp-login-probe, 2 tries each, counts toward QMAXSIGN), and one profile you supply to see what it can browse and whether RCMD is advertised (never run). Read-only verb whitelist. Replies were modelled from documentation, confirm on real hardware.

z/VM

Tool	What It Does	Direct Use	Benefit
VM Minidisk Password Exposure	Shows that a LINK command's minidisk password renders in cleartext at the CP READ prompt, since CP has no masked-input primitive for command arguments.	Connect to a z/VM CP session, type a real LINK command with a password.	A simple, visual way to demonstrate that CP command-line arguments are never masked, something a lot of z/VM shops don't realize about their own console.

z/TPF

Tool	What It Does	Direct Use	Benefit
ECB Enumerator	ZSHOW E - lists every	Run at the operator	A full map of what's
Privilege Scanner	Probes entry the CPE Block /	Run at the operator	Confirms exactly what
Entry Point Prober	and ZTEST against SYSPROG	Run at the operator	Finds privilege the, starting
Pool Monitor	ZCBCHK Reports reports	Run at the operator	Early and type, fast
System Diagnostics	and ZTPDMP, and capacity	Run at the operator	the ZTPDMP the
Entry Point Debugger	the LOCK/UNLOCK ZTEST	Run at the operator	the safely, that
Hardening Audit	START -zDEBUG, and	Run at the operator	Detailed gaps,

Not a tool: z/TPF deep-internals methodology

Storage-protection-key escalation, core/memory-block corruption, and record-pointer injection are real z/TPF risk categories, but they're deliberately not shipped as a live tool here: a bug in a browser-based probe for any of them risks an outage on what's typically a production airline reservation system. DOCUMENTATION/ztpf-deep-internals-methodology.md covers the actual approach, source and macro review, then isolated-lab testing only once review produces a specific hypothesis, and ties back to the Entry Point Debugger above as a safe, live way to demonstrate the concept.

Everything above runs from one bridge, one browser client, against real TN3270(E)/TN5250 protocol, real EBCDIC, and either a live mainframe or the project's own mock LPAR fleet for a zero-risk demo. Project, docs, and source: github.com/wren-creator/web3270.